

Cyber Threat Intelligence

Executive Briefing

Report Date: July 05, 2026

Generated: 2026-07-05 20:05 UTC | Classification: TLP:AMBER

Prepared by: Auto-CTI Autonomous Threat Intelligence Pipeline

1. Risk Statistics Summary

Critical	High	Medium	Low	Total
4	11	4	1	20

2. Executive Summary

This briefing serves as the official cyber threat intelligence report for July 05, 2026, encompassing a total of 20 analyzed vulnerabilities. The current security posture is classified as elevated, with a distribution of 4 Critical, 11 High, 4 Medium, and 1 Low severity findings requiring immediate remediation to address systemic risks. The primary threat is CVE-2026-49360, Unauthorized SQL Execution in Recce Server, which represents the highest priority due to the absence of authentication controls, directly enabling unauthorized database manipulation. We recommend an immediate transition to an active defense posture, prioritizing the remediation of all critical and high-severity items to maintain operational integrity. Continued non-compliance with these patching directives introduces unacceptable levels of risk to the enterprise production environment.

3. Critical Action List

- Immediate patching of CVE-2026-49360 in the Recce server to implement mandatory authentication controls within 24 hours.
- Immediate remediation of CVE-2026-49352 to rotate the hardcoded JWT secret in 9router within 24 hours.
- Immediate implementation of input validation and directory sanitization for CVE-2026-54617 within 24 hours.
- Apply vendor-issued patches for CVE-2026-52830 to enforce strict file access controls within 48 hours.
- Update Steeltoe configurations for CVE-2026-50194 to enforce rigorous Host header validation within 72 hours.

4. Quick Reference: All Identified Vulnerabilities

CVE ID	Finding Name	CVSS	Severity	Urgency	CWE
CVE-2026-49360	Unauthorized SQL Execution in Rec...	9.8	Critical	88/100	CWE-73
CVE-2026-49352	Authentication Bypass via Hardcod...	9.8	Critical	88/100	CWE-798

CVE-2026-54617	Unauthenticated Path Traversal in...	9.8	Critical	88/100	CWE-22
CVE-2026-52830	Path Traversal in fast-mcp-teleg...	9.4	Critical	85/100	CWE-22
CVE-2026-50194	Host Header Isolation Bypass in S...	8.2	High	74/100	CWE-288
CVE-2026-2092	Unauthorized SAML Assertion Acces...	7.7	High	69/100	CWE-1287
CVE-2026-49353	Access Gate Bypass in 9router	7.5	High	68/100	CWE-290
CVE-2026-46599	Resource Exhaustion in golang.org...	7.5	High	68/100	CWE-770
CVE-2026-52792	Source Disclosure in Algernon via...	7.5	High	68/100	CWE-69
CVE-2026-50200	Credential Leakage in Steeltoe En...	7.5	High	68/100	CWE-200
CVE-2026-50196	Registry Poisoning in Steeltoe Di...	7.5	High	68/100	CWE-20
CVE-2026-49289	XPath Denial of Service in Simple...	7.5	High	68/100	CWE-400
CVE-2026-52829	Mempool Misbehavior in Zebra Addr...	7.5	High	68/100	CWE-617
CVE-2026-52834	Out-of-Bounds Write in jxl-grid	7.3	High	66/100	CWE-122
CVE-2026-49284	SAML Response Validation Bypass i...	8.1	High	64/100	CWE-345
CVE-2026-50201	Restricted Permission Bypass in S...	6.5	Medium	59/100	CWE-269
CVE-2026-50202	JWKS Cache Poisoning in Steeltoe	5.9	Medium	53/100	CWE-668
CVE-2026-50267	Sensitive Key Exposure in Steeltoe	4.7	Medium	42/100	CWE-312
CVE-2026-49292	Improper Access Control in Kiwi T...	5.3	Medium	39/100	CWE-862
CVE-2026-50268	Weak Padding Selection in Steeltoe	1.9	Low	12/100	CWE-256

5. Detailed Vulnerability Findings

CVE-2026-49360

Finding: Unauthorized SQL Execution in Recce Server

CVSS v3.1 Score: 9.8 | Severity: Critical | Urgency Score: 88/100 | CWE: CWE-73

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1190, T1505

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

The Recce server component utilizes DuckDB to process queries without implementing sufficient authentication checks during execution. This vulnerability stems from a failure to validate request origins before invoking internal file read/write operations within the database engine. Unauthenticated remote attackers can leverage this flaw to perform arbitrary file system operations, leading to full server compromise.

Proof of Concept (PoC):

An unauthenticated remote attacker accesses the Recce server management interface. The attacker sends a malicious SQL query via the primary API endpoint, intended for the underlying DuckDB engine. The server fails to enforce session-based authorization before dispatching the query to the file system interface. The attacker successfully gains read and write access to sensitive configuration and system files.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49360>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49360>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49360>

CVE-2026-49352

Finding: Authentication Bypass via Hardcoded JWT Secret

CVSS v3.1 Score: 9.8 | Severity: Critical | Urgency Score: 88/100 | CWE: CWE-798

Score Provenance: Estimated (Unverified) - Vector Recalculated
MITRE ATT&CK: T1552, T1078

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

9router employs a hardcoded fallback JWT secret in its authentication module which is used when primary configuration is absent. This flaw stems from a lack of secure secret management practices during the application build process. An unauthenticated attacker can exploit this static secret to forge valid JWT tokens, effectively bypassing authentication controls and gaining administrative access.

Proof of Concept (PoC):

An unauthenticated remote attacker discovers the publicly known hardcoded secret key associated with 9router deployments. The attacker generates a custom JWT with elevated administrative claims using the retrieved secret. The attacker presents this forged token to the authentication middleware. The application validates the signature successfully, granting the attacker full administrative privileges.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49352>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49352>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49352>

CVE-2026-54617

Finding: Unauthenticated Path Traversal in LaunchServer

CVSS v3.1 Score: 9.8 | Severity: Critical | Urgency Score: 88/100 | CWE: CWE-22

Score Provenance: Estimated (Unverified) - Vector Recalculated
MITRE ATT&CK: T1083, T1005

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None

Attack Complexity	Low
User Interaction	None

Scope	Unchanged
Integrity Impact	High

Confidentiality Impact	High
Availability Impact	High

Description:

The FileServerHandler component in LaunchServer allows unauthenticated attackers to escape the restricted root directory via path traversal sequences. This flaw originates from improper sanitization of user-supplied input paths during file read operations. An unauthenticated remote attacker can read arbitrary files from the host system, leading to the disclosure of sensitive data.

Proof of Concept (PoC):

An unauthenticated remote attacker sends a specially crafted GET request to the file server handler containing '..%2f' sequences. The handler processes the relative path without effectively constraining the base directory. The server resolves the path outside the intended scope and serves content from sensitive system directories. This results in the exposure of configuration files and local credentials.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-54617>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-54617>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-54617>

CVE-2026-52830

Finding: Path Traversal in fast-mcp-telegram

CVSS v3.1 Score: 9.4 | Severity: Critical | Urgency Score: 85/100 | CWE: CWE-22

Score Provenance: CNA Official

MITRE ATT&CK: T1005, T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:L

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	Low

Description:

The fast-mcp-telegram handler fails to restrict file access when handling Bearer token authorization requests, allowing path traversal bypasses. This flaw results from insufficient input normalization when verifying the session token path against the reserved Telegram session directory. An unauthenticated attacker can traverse the file system to read protected session data.

Proof of Concept (PoC):

An unauthenticated remote attacker sends an HTTP request containing a directory traversal path within the Authorization header. The application fails to sanitize the path, instead treating the traversal sequence as part of the session token validation logic. The attacker accesses the file system and reads sensitive Telegram session files. This allows the attacker to hijack active Telegram sessions.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52830>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52830>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52830>

CVE-2026-50194

Finding: Host Header Isolation Bypass in Steeltoe

CVSS v3.1 Score: 8.2 | Severity: High | Urgency Score: 74/100 | CWE: CWE-288

Score Provenance: CNA Official

MITRE ATT&CK: T1133

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N

Attack Vector	Network	Attack Complexity	Low
Privileges Required	None	User Interaction	None
Scope	Unchanged	Confidentiality Impact	High
Integrity Impact	Low	Availability Impact	None

Description:

Steeltoe's management-port isolation mechanism is bypassed when the application fails to validate the Host header correctly in forwarded requests. This vulnerability occurs due to the reliance on potentially spoofable HTTP headers to determine the target security context for management endpoints. An unauthenticated remote attacker can gain unauthorized access to isolated management functions.

Proof of Concept (PoC):

An unauthenticated remote attacker sends a request to the application management port while spoofing the Host header to match an internal-only allowed value. The Steeltoe middleware accepts the header at face value and routes the request to the isolated management controller. The controller assumes the request is local and bypasses normal security authentication. The attacker successfully interacts with privileged management functions.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50194>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50194>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50194>

CVE-2026-2092

Finding: Unauthorized SAML Assertion Access in Keycloak

CVSS v3.1 Score: 7.7 | Severity: High | Urgency Score: 69/100 | CWE: CWE-1287

Score Provenance: CNA Official

MITRE ATT&CK: T1068, T1550

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:C/C:H/I:L/A:L

Attack Vector	Network	Attack Complexity	High
Privileges Required	Low	User Interaction	None
Scope	Changed	Confidentiality Impact	High
Integrity Impact	Low	Availability Impact	Low

Description:

Keycloak fails to properly validate the encryption structures within SAML assertions, leading to unauthorized access for authenticated users. This issue arises due to flaws in the cryptographic validation chain that occur when processing encrypted tokens. An authenticated user can exploit this weakness to escalate their privileges within the application scope.

Proof of Concept (PoC):

An authenticated user with low privileges captures their own SAML assertion from a Keycloak session. The attacker

modifies the encrypted components of the assertion by applying a specially crafted wrapper that bypasses validator checks. The attacker presents this manipulated token back to the service endpoint. The server accepts the assertion, elevating the attacker's context to a more privileged role.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-2092>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-2092>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-2092>

CVE-2026-49353

Finding: Access Gate Bypass in 9router

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-290

Score Provenance: Estimated (Unverified) - Vector Recalculated
MITRE ATT&CK: T1133, T1036

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network	Attack Complexity	Low
Privileges Required	None	User Interaction	None
Scope	Unchanged	Confidentiality Impact	High
Integrity Impact	None	Availability Impact	None

Description:

The 9router application exhibits a flawed access control mechanism that relies on the Host header to restrict administrative functionality to local requests. Improper validation of HTTP headers allows an attacker to manipulate the Host field to bypass these location-based security checks. This grants unauthorized remote actors access to administrative interfaces that are intended to be local-only.

Proof of Concept (PoC):

An unauthenticated remote attacker intercepts traffic to the 9router gateway service. The attacker modifies the HTTP Host header to 'localhost' or an internal administrative domain. The application logic accepts the spoofed header and permits access to privileged management endpoints. The attacker gains the ability to view sensitive internal system configurations and routing tables.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49353>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49353>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49353>

CVE-2026-46599

Finding: Resource Exhaustion in golang.org/x/image/tiff

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-770

Score Provenance: Estimated (No Official CVSS) - Vector Recalculated
MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network	Attack Complexity	Low
Privileges Required	None	User Interaction	None
Scope	Unchanged	Confidentiality Impact	None

Integrity Impact	None	Availability Impact	High
------------------	------	---------------------	------

Description:

The PackBits decompression routine within `golang.org/x/image/tiff` suffers from insufficient resource consumption limits when processing malformed TIFF image headers. The logic fails to validate decompression ratios, leading to excessive memory allocation when handling specially crafted image data. This vulnerability can be exploited by an unauthenticated attacker to trigger an out-of-memory condition, resulting in service denial.

Proof of Concept (PoC):

An unauthenticated remote attacker submits a malformed TIFF image file containing a crafted PackBits compression stream. The application passes this file to the image processing library, where it attempts to allocate massive amounts of heap memory based on the header parameters. The application exhausts available system resources, triggering a crash and rendering the service unavailable.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-46599>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-46599>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-46599>

CVE-2026-52792

Finding: Source Disclosure in Algernon via NTFS

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-69

Score Provenance: Estimated (Unverified) - Vector Recalculated
MITRE ATT&CK: T1005, T1592

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network	Attack Complexity	Low
Privileges Required	None	User Interaction	None
Scope	Unchanged	Confidentiality Impact	High
Integrity Impact	None	Availability Impact	None

Description:

Algernon is susceptible to server-side script source disclosure on Windows systems when using specific NTFS file stream naming conventions. This vulnerability arises because the web server does not correctly handle alternate data streams that point to script source files. An unauthenticated attacker can download the underlying source code of the application, leading to severe information exposure.

Proof of Concept (PoC):

An unauthenticated remote attacker identifies an Algernon-served script on a Windows host. The attacker appends a specific NTFS alternate data stream syntax (e.g., `::$DATA`) to the request URL. The server bypasses script execution and returns the file content as plain text. The attacker successfully downloads the source code, potentially discovering hardcoded credentials or business logic secrets.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52792>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52792>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52792>

CVE-2026-50200

Finding: Credential Leakage in Steeltoe Env Sanitizer

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-200

Score Provenance: CNA Official

MITRE ATT&CK: T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

Steeltoe's environment variable sanitizer fails to redact embedded connection strings containing database passwords. This vulnerability occurs because the sanitizer logic does not apply pattern matching to substrings within connection objects. An unauthenticated attacker can query the environment dump endpoint to retrieve cleartext database credentials.

Proof of Concept (PoC):

An unauthenticated remote attacker accesses the application's diagnostics endpoint that exposes environment configurations. The sanitizer removes standard variables but misses the embedded secrets hidden within connection strings. The attacker views the unredacted output containing the database administrator credentials. The attacker uses these credentials to access and modify the backend database.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50200>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50200>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50200>

CVE-2026-50196

Finding: Registry Poisoning in Steeltoe Discovery

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-20

Score Provenance: CNA Official

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

Steeltoe.Discovery.Eureka is vulnerable to registry poisoning because it fails to sanitize unrecognized DataCenterInfo.Name inputs when processing registry fetches. This input validation failure allows attackers to inject data that corrupts the internal service registry for all instances. An unauthenticated remote attacker can trigger a denial-of-service condition across the entire service discovery cluster.

Proof of Concept (PoC):

An unauthenticated remote attacker submits a specially crafted registration request to the Eureka server with a poisoned DataCenterInfo.Name attribute. The Steeltoe client receives this corrupted registry fetch response, leading to a state

mismatch in the registry processing code. The service discovery client enters an infinite loop or crashes upon attempting to parse the metadata. This effectively halts all traffic redirection for the affected services.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50196>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50196>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50196>

CVE-2026-49289

Finding: XPath Denial of Service in SimpleSAMLphp

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-400

Score Provenance: Estimated (Unverified) - Vector Recalculated
MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

SimpleSAMLphp is susceptible to a denial of service attack through the processing of XPath transformations in XML assertions. This vulnerability exists because the underlying XML processing library fails to limit the depth or complexity of recursive XPath queries. An unauthenticated attacker can submit a crafted XML document that causes excessive CPU utilization on the server.

Proof of Concept (PoC):

An unauthenticated remote attacker sends an XML-based authentication request containing a deeply nested XPath expression. The SimpleSAMLphp engine parses the assertion and executes the malicious transformation recursively. The server consumes all available CPU cycles trying to resolve the complex query. This renders the authentication service unresponsive to legitimate login requests.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49289>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49289>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49289>

CVE-2026-52829

Finding: Mempool Misbehavior in Zebra Address Book

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-617

Score Provenance: Estimated (Unverified) - Vector Recalculated
MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

The Zebra Address Book exhibits memory pool instability when processing malformed IPv4-mapped address structures. This vulnerability arises from an assertion failure (CWE-617) triggered by invalid memory pointer arithmetic within the address processing routine. A remote attacker can trigger this issue to cause service aborts and application crashes.

Proof of Concept (PoC):

An unauthenticated remote attacker sends a specially formatted network packet containing an invalid IPv4-mapped address to the Zebra service. The service parses the address field and invokes a memory pool function that encounters an unexpected condition. The application triggers an abort signal and crashes. The attacker successfully performs a denial-of-service attack on the address book component.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52829>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52829>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52829>

CVE-2026-52834

Finding: Out-of-Bounds Write in jxl-grid

CVSS v3.1 Score: 7.3 | Severity: High | Urgency Score: 66/100 | CWE: CWE-122

Score Provenance: Estimated (Unverified) - Vector Recalculated
MITRE ATT&CK: T1210

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:L/I:H/A:H

Attack Vector	Local	Attack Complexity	Low
Privileges Required	Low	User Interaction	None
Scope	Unchanged	Confidentiality Impact	Low
Integrity Impact	High	Availability Impact	High

Description:

The jxl-grid library exhibits an integer overflow vulnerability when calculating buffer sizes on 32-bit platforms, leading to an out-of-bounds write. This flaw occurs due to a lack of safe arithmetic checks during the allocation of heap memory. A local attacker or remote process providing malicious image metadata can trigger a buffer overflow, potentially allowing code execution.

Proof of Concept (PoC):

A local attacker provides a malformed grid metadata file with dimensions designed to trigger an integer overflow on 32-bit pointer arithmetic. The library calculates an insufficient buffer size but copies data based on the original dimensions. The resulting heap-based buffer overflow allows the attacker to corrupt adjacent memory segments. This leads to arbitrary code execution within the context of the user running the application.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52834>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52834>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52834>

CVE-2026-49284

Finding: SAML Response Validation Bypass in SimpleSAMLphp

CVSS v3.1 Score: 8.1 | Severity: High | Urgency Score: 64/100 | CWE: CWE-345

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1550

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	High
Availability Impact	None

Description:

SimpleSAMLphp service provider accepts SAML responses from unauthorized Identity Providers (IdP) due to flawed validation logic involving unsigned Response/InResponseTo attributes. This issue occurs when an assertion is signed but the surrounding Response lacks necessary linkage, allowing for cross-IdP response injection. A remote attacker can impersonate users by providing malicious but structurally valid SAML assertions.

Proof of Concept (PoC):

An unauthenticated remote attacker captures a legitimate but expired SAML assertion. The attacker crafts a new, unsigned Response envelope and attaches the stolen signed assertion, omitting the InResponseTo field requirements. The SimpleSAMLphp SP consumes the response and validates the signature, failing to verify that the IdP matches the expected provider. The attacker successfully authenticates to the target service as an arbitrary user.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49284>Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49284>Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49284>**CVE-2026-50201****Finding: Restricted Permission Bypass in Steeltoe Actuators****CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 59/100 | CWE: CWE-269**

Score Provenance: CNA Official

MITRE ATT&CK: T1068, T1592

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

Steeltoe's management actuators expose sensitive information such as heap dumps and environment variables to users with only 'Restricted' level permissions. This flaw arises from insufficient role-based access control (RBAC) mappings in the actuator security filter. An attacker with a low-privileged account can retrieve sensitive system-level diagnostic information.

Proof of Concept (PoC):

A low-privileged user authenticates to the application and sends a request to the /actuator/heapdump endpoint. The security filter incorrectly evaluates the user's 'Restricted' role as sufficient for access. The server provides a full binary heap dump containing memory state. The attacker analyzes the dump to extract sensitive application secrets and sensitive user data.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50201>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50201>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50201>

CVE-2026-50202

Finding: JWKS Cache Poisoning in Steeltoe

CVSS v3.1 Score: 5.9 | Severity: Medium | Urgency Score: 53/100 | CWE: CWE-668

Score Provenance: CNA Official
MITRE ATT&CK: T1550

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:H/UI:N/S:U/C:H/I:H/A:N

Attack Vector	Network
Privileges Required	High
Scope	Unchanged
Integrity Impact	High

Attack Complexity	High
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

Steeltoe caches JWKS (JSON Web Key Set) information globally, sharing keys across distinct authentication schemes without invalidation logic. This occurs because the cache implementation lacks scope-aware keys, causing a persistent state collision. A privileged attacker can inject or force the caching of malicious keys to manipulate authentication for all connected services.

Proof of Concept (PoC):

An attacker with high privileges modifies the source JWKS endpoint to point to a controlled malicious key set. The Steeltoe application fetches and caches these malicious keys, applying them globally across all authentication schemes. Any subsequent user authentication attempts are validated against the attacker-controlled key set. The attacker successfully impersonates legitimate entities across the entire application ecosystem.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50202>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50202>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50202>

CVE-2026-50267

Finding: Sensitive Key Exposure in Steeltoe

CVSS v3.1 Score: 4.7 | Severity: Medium | Urgency Score: 42/100 | CWE: CWE-312

Score Provenance: CNA Official
MITRE ATT&CK: T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:L/AC:H/PR:L/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Local
Privileges Required	Low
Scope	Unchanged
Integrity Impact	None

Attack Complexity	High
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

Steeltoe insecurely writes TLS private keys to /tmp with default, readable permissions and fails to clean up these files

post-process. This security flaw originates from poor file handling policies during TLS certificate initialization. A local attacker can read these sensitive files, leading to a total compromise of TLS communication integrity.

Proof of Concept (PoC):

A local attacker with read access to the system /tmp directory monitors file creation events during application boot. The attacker identifies the temporary file containing the active TLS private key created by Steeltoe. The attacker copies this file before the process cleans it up. The attacker now possesses the server's private key, enabling man-in-the-middle attacks on the application's traffic.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50267>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50267>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50267>

CVE-2026-49292

Finding: Improper Access Control in Kiwi TCMS

CVSS v3.1 Score: 5.3 | Severity: Medium | Urgency Score: 39/100 | CWE: CWE-862

Score Provenance: Estimated (Unverified) - Vector Recalculated
MITRE ATT&CK: T1068

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	None

Description:

The Kiwi TCMS /init-db/ page fails to disable functionality after the initial database deployment is complete. This authorization weakness occurs because the initialization controller lacks a state check to verify if the installation has already been performed. An unauthenticated attacker can trigger this page to potentially overwrite or manipulate the database configuration.

Proof of Concept (PoC):

An unauthenticated remote attacker navigates to the /init-db/ URI on an already deployed Kiwi TCMS instance. The system executes the initialization routine again as it does not verify the application's current state. The attacker triggers a re-initialization process that could corrupt existing records or expose installation parameters. This allows for partial integrity loss regarding the system's database state.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49292>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49292>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49292>

CVE-2026-50268

Finding: Weak Padding Selection in Steeltoe

CVSS v3.1 Score: 1.9 | Severity: Low | Urgency Score: 12/100 | CWE: CWE-256

Score Provenance: CNA Official
MITRE ATT&CK: T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:L/AC:H/PR:H/UI:N/S:U/C:L/I:N/A:N

Attack Vector	Local
Privileges Required	High
Scope	Unchanged
Integrity Impact	None

Attack Complexity	High
User Interaction	None
Confidentiality Impact	Low
Availability Impact	None

Description:

The Steeltoe library incorrectly falls back to PKCS#1 v1.5 padding when OAEP is requested but misconfigured, weakening cryptographic protections. This issue stems from a configuration logic error that fails to validate that the encryption padding standard is correctly applied. A privileged attacker with local access could potentially exploit this to perform chosen-ciphertext attacks on sensitive data.

Proof of Concept (PoC):

A privileged local attacker modifies the application configuration files to trigger the OAEP misconfiguration. The attacker then provides ciphertext encrypted with the weaker PKCS#1 v1.5 padding. The system decrypts the data as if it were valid OAEP, allowing the attacker to observe timing-based side channels. The attacker gradually recovers portions of plaintext data previously thought to be secure.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50268>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50268>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50268>

6. Methodology & Data Sources

This report was generated by the Auto-CTI Autonomous Cyber Threat Intelligence Pipeline, an automated multi-agent system designed to simulate a real-world Security Operations Center (SOC) workflow. The pipeline operates in three sequential stages: (1) the Scout Agent collects the latest CVE disclosures from NVD, the GitHub Advisory Database, and OSV.dev, cross-referencing active threat pulses via AlienVault OTX; (2) the Triage Agent performs structured analysis using the CVSS v3.1 scoring standard, assigns CWE root-cause classifications, maps each vulnerability to relevant MITRE ATT&CK techniques, and computes a composite Urgency Score; (3) the Publisher Agent synthesizes the triaged data into this executive briefing. Every CVSS score is tagged with a Score Provenance label indicating whether it was confirmed against an official database (NVD or CNA record) or estimated by the analysis model when no official score existed. All CVE identifiers, CVSS scores, and CWE mappings are independently verifiable via the references provided in Section 5. References marked 'Fallback Search' indicate the specific CVE record was not found live at NVD or CVE.org at generation time; a source-database search link is provided instead. Severity classification follows the CVSS v3.1 standard: Critical (9.0-10.0), High (7.0-8.9), Medium (4.0-6.9), Low (0.1-3.9).

Primary Data Sources:

- NIST National Vulnerability Database (NVD) -- <https://nvd.nist.gov/>
- GitHub Advisory Database -- <https://github.com/advisories>
- OSV.dev Open Source Vulnerabilities -- <https://osv.dev/>
- CVE Services API (MITRE CNA Records) -- <https://cveawg.mitre.org/>
- OpenCVE -- <https://www.opencve.io/>
- AlienVault Open Threat Exchange (OTX) -- <https://otx.alienvault.com/>
- MITRE ATT&CK Framework -- <https://attack.mitre.org/>
- CVSS v3.1 Specification -- <https://www.first.org/cvss/v3.1/specification-document>

- Common Weakness Enumeration (CWE) -- <https://cwe.mitre.org/>
- CVE Program -- <https://www.cve.org/>